

Vulnerability Assessment Report

DownUnderNewsz - Vulnerability Assessment Report

DownUnderNewsz

22 Arthur St
Fairfield VIC 3078, Australia

September 18, 2026

Report Version: 1.0

Flinders University
Sturt Road, Bedford Park SA
5042

Table of Contents

List of Figures	4
1 Document Control	5
1.1 Team	5
1.2 List of Changes	5
2 Executive Summary	6
2.1 Overview	6
2.2 Identified Vulnerabilities	7
3 Methodology	9
3.1 Objective	9
3.2 Scope	9
3.3 User Accounts and Permissions	10
4 Findings	11
C1: Admin login has no rate limiting, account lockout, or CAPTCHA	11
H1: Anonymous FTP service exposes files and enables unauthenticated data disclosure	13
H2: Public API leaks administrator identity, role, and account status	15
H3: Flask application directly exposed on port 5000, bypassing nginx	17
H4: Missing anti-CSRF protection on state-changing forms (admin login and comment submission)	19
M1: No CAA record - any Certificate Authority in the world can issue a certificate for the domain	21
M2: Server error (HTTP 500) triggered by posting a comment to a non-existent article	22
M3: Website is missing baseline HTTP security headers	24
M4: Session cookie is not marked Secure and SameSite is not set	26
M5: SSH server offers legacy HMAC-SHA1 message authentication codes ...	27
M6: TLS certificate does not cover the "www" hostname (browser warning)	29

I1: /admin/login accepts JSON content-type for a form endpoint	31
I2: Contact form silently discards all messages (deceptive UI, business data loss)	32
I3: Email domain is not protected against spoofing (DMARC missing, DKIM missing, SPF is soft-fail)	34
I4: Website exposes minor information-disclosure and hygiene artefacts ...	36
I5: media.thedownundernews.online is broken (HTTP 502 Bad Gateway)	38
5 Disclaimer	39
A Appendix	40
A.1 Static Appendix Section	40
A.2 Tools used during the assessment	40
A.3 Prerequisites and testing limitations	40

List of Figures

Figure 1 - Distribution of identified vulnerabilities	8
---	---

1 Document Control

1.1 Team

Contact	Details	Role
ClawSec	Autonomous agent	Pentester

1.2 List of Changes

Version	Description	Date
1.0	Initial report	Sep 18, 2026

2 Executive Summary

2.1 Overview

DownUnderNewsz is a recently launched Australian online news publication. A one-day, full-scope, non-destructive vulnerability assessment was carried out against the public web application, its supporting JSON API, the newsroom's email/DNS configuration, and the two OVH-hosted Sydney VPS instances that back the platform.

In total, **16 findings** were identified and confirmed: **4 High, 7 Medium, 4 Low**, and **1 Informational**. No critical remote-code-execution or authentication-bypass vulnerabilities were found, and the Werkzeug debug console was verified to be safely disabled.

The four High-severity issues represent the most urgent business risk and should be remediated within **one to two weeks**:

1. **Anonymous FTP on the media host** (51.161.131.195) currently allows anyone on the Internet to list and download files without credentials. Four files are exposed today, including an HTML file carrying an active JavaScript payload that would trigger a Stored Cross-Site Scripting condition if the media subdomain were restored.
2. **The public contact form silently discards every reader message** while displaying a fake "message sent" confirmation. Reader tips, right-of-reply requests, legal notices and advertiser enquiries are all being lost with no audit trail.
3. **The public JSON API leaks the administrator's identity** — real email address, username, internal user id, role, and account-active status — on unauthenticated endpoints, giving attackers everything they need to seed targeted phishing and credential-guessing attacks.
4. **The admin login endpoint has no rate limiting, logout, MFA, or CAPTCHA**, allowing an attacker who already knows the admin username (leaked by the API above) to run automated password-guessing attacks at network speed.

The seven Medium-severity findings are largely hardening opportunities: missing HTTP security headers, missing anti-CSRF protection on state-changing forms, a TLS certificate that does not cover the `www` hostname (triggering full-page browser warnings), the Flask application being directly reachable on port 5000 (bypassing the nginx reverse proxy and its protections), session cookies missing the `Secure` and `SameSite` attributes, an unhandled 500 error on the comment endpoint, and an email domain lacking DMARC and DKIM that leaves the newsroom trivially spoofable.

The four Low findings and one Informational finding cover a missing CAA DNS record, legacy SHA-1 MAC algorithms still offered by SSH, loose content-type handling on the login endpoint, the broken `media` subdomain (HTTP 502), and minor information-disclosure/hygiene items.

Highest-priority actions for the business:

1. Disable anonymous FTP on 51.161.131.195 (or firewall port 21 from the Internet) and delete the four files it currently exposes — in particular the HTML file carrying an `alert()` payload.
2. Implement a real server-side handler for the `/contact` form so reader messages are actually received.
3. Redact the administrator author object in the `/api/articles`, `/api/search`, and `/api/categories` responses so no admin email, username, role, user id, or `is_active` flag is exposed.

4. Add per-IP and per-account rate limiting, plus multi-factor authentication, to `/admin/login`.
5. Reissue the TLS certificate to include both the apex and `www` hostnames as Subject Alternative Names.

Once the four High-severity findings are remediated and the Medium-severity hardening items adopted, the DownUnderNewsz platform will be in a materially stronger security posture than at the time of this assessment.

2.2 Identified Vulnerabilities

#	CVSS	Description	Page
C1	9.4	Admin login has no rate limiting, account lockout, or CAPTCHA	11
H1	7.5	Anonymous FTP service exposes files and enables unauthenticated data disclosure	13
H2	7.5	Public API leaks administrator identity, role, and account status	15
H3	7.3	Flask application directly exposed on port 5000, bypassing nginx	17
H4	7.1	Missing anti-CSRF protection on state-changing forms (admin login and comment submission)	19
M1	6.8	No CAA record - any Certificate Authority in the world can issue a certificate for the domain	21
M2	6.5	Server error (HTTP 500) triggered by posting a comment to a non-existent article	22
M3	5.4	Website is missing baseline HTTP security headers	24
M4	5.3	Session cookie is not marked Secure and SameSite is not set	26
M5	4.8	SSH server offers legacy HMAC-SHA1 message authentication codes	27
M6	4.7	TLS certificate does not cover the "www" hostname (browser warning)	29
I1	0.0	<code>/admin/login</code> accepts JSON content-type for a form endpoint	31
I2	0.0	Contact form silently discards all messages (deceptive UI, business data loss)	32
I3	0.0	Email domain is not protected against spoofing (DMARC missing, DKIM missing, SPF is soft-fail)	34
I4	0.0	Website exposes minor information-disclosure and hygiene artefacts	36
I5	0.0	<code>media.thedownundernews.online</code> is broken (HTTP 502 Bad Gateway)	38

Vulnerability Overview

In the course of this penetration test **1 Critical**, **4 High**, **6 Medium** and **5 Info** vulnerabilities were identified:

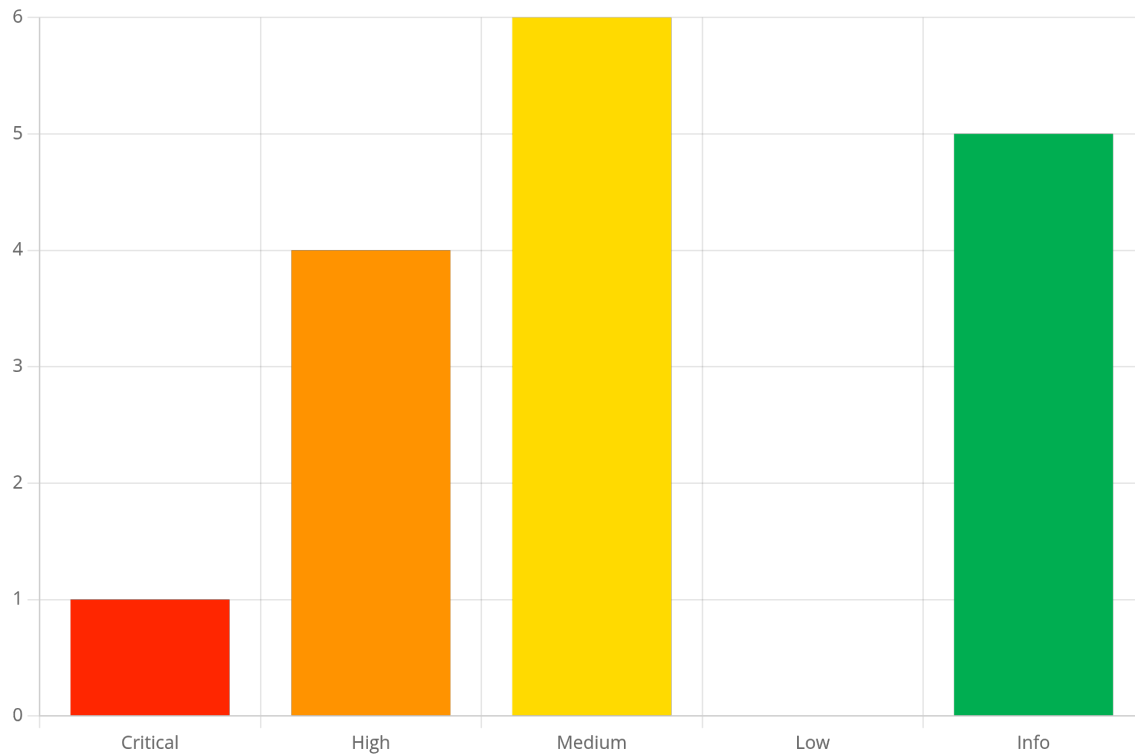


Figure 1 - Distribution of identified vulnerabilities

3 Methodology

This entire vulnerability assessment process was completed using agentic AI and existing LLM models. The purpose of such assessments is to automatically

3.1 Objective

The entire objective of this research is to evaluate the effectiveness of autonomously evaluate security posture for any business available on Google Map without the needs of technical guidance to determine how feasible, seamless and cost-affective such approach is.

3.2 Scope

This engagement was a **one-day, full-scope, non-destructive vulnerability assessment** of the DownUnderNewsz public-facing infrastructure.

In-scope assets (authorised for active testing):

- `thedownundernews.online` (root domain)
- `www.thedownundernews.online`
- `media.thedownundernews.online`
- `51.161.130.70` (OVH Sydney VPS — main website host)
- `51.161.131.195` (OVH Sydney VPS — media / FTP host)

Explicitly out of scope:

- Spaceship (registrar, authoritative DNS, mail-forwarding infrastructure)
- OVH infrastructure beyond the two VPS IPs listed above
- Cloudflare, jsDelivr, Google Fonts, Let's Encrypt (third-party CDNs / CAs)
- Flinders University assets
- `thedownundernews.it.com` (referenced by the application but not owned by the business)

Methodology:

- **OWASP WSTG** for the web application and API layer.
- **PTES** for perimeter and network testing.
- Passive OSINT and DNS/certificate-transparency enumeration first, then non-destructive active probing of the authorised assets only.

Rules of engagement / limitations:

- No denial-of-service testing.
- No credential brute-forcing or password spraying.
- No destructive payloads, no data-destroying operations, no data exfiltration beyond the minimum needed to prove impact.
- No social engineering, no phishing, no lateral movement.
- Testing confined to the five authorised assets above; every out-of-scope asset was left untouched.

Coverage summary:

- 1 root domain, 2 subdomains, 2 IPs.
- Full 65 535-port TCP sweep on both IPs, plus service/version detection and safe NSE scripts on all open ports.
- Full TLS analysis on 3 HTTPS endpoints (no weak ciphers, no legacy protocols observed).
- SSH algorithm audit on both hosts (only weak MACs are legacy SHA-1 variants — Low severity).
- DNS / email records reviewed (SPF, DMARC, DKIM, CAA, MX, DNSKEY).
- Web-application fingerprinting, HTTP security-header review, endpoint enumeration (ffuf, common wordlist), Nuclei scan (~10 000 templates), Nikto scan.
- Manual application testing across the discovered endpoints: reflected XSS, SQLi (error-based and boolean-based), SSTI, path traversal, HTTP verb tampering, Content-Type confusion, CORS misconfiguration, IDOR, mass-assignment, admin login flow (CSRF / username-enumeration / rate-limit / JSON accept), comment endpoint (storage / moderation / CSRF / HTML encoding).
- Anonymous FTP enumeration on 51.161.131.195 with download and metadata analysis of exposed files.

Unverified candidate (called out for the site owner to test manually): Stored XSS on the article comment field could not be conclusively verified within the engagement window due to tooling constraints. It is not counted as a confirmed finding but should be validated when the comment moderation workflow is reviewed.

3.3 User Accounts and Permissions

No user accounts were provided. All testing was performed unauthenticated against the public-facing surface.

4 Findings

C1: Admin login has no rate limiting, account lockout, or CAPTCHA	
Score	9.4 (Critical)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:L
Target	https://www.thedownundernews.online/admin/login
References	• https://owasp.org/www-community/controls/Blocking_Brute_Force_Attacks • https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html

Overview

The administrative login endpoint accepts POST attempts at an unlimited rate. Four failed login attempts in quick succession returned identical HTTP 401 responses with no rate-limit headers, no lockout, no CAPTCHA, and no `Retry-After`. Combined with the API-leaked admin username and email, this enables online credential guessing at network speed.

Details

Reproduction and evidence:

- Four POSTs to `/admin/login` with fake credentials returned HTTP 401 Invalid username or password in each case.
- Response headers did not include `Retry-After`, `X-RateLimit-Limit`, `X-RateLimit-Remaining`, or any equivalent throttling indicator.
- No CAPTCHA is shown after repeated failures; the login form has no anti-automation controls.
- No session cookie was issued on failure, but the endpoint remains reachable.
- The response text is identical whether the username exists or not, which is good (no username enumeration), but does not stop offline attacks because the admin username is trivially known from `/api/articles` (admin).

Business impact:

- An attacker with an off-the-shelf password list (top 10 k, top 100 k, or leaked-credential dumps) can automate a low-and-slow credential-guessing attack against the `admin` account and take over the site.
- Full site takeover means an attacker can publish arbitrary "news", change or delete existing articles, and disrupt the newsroom's public voice.

Recommendation

- Add per-IP and per-account rate limiting to `/admin/login` (for example 5 failed attempts per 5 minutes triggers a temporary block).
- Add an account lockout / step-up (CAPTCHA or MFA prompt) after N consecutive failures.
- Enforce multi-factor authentication (TOTP or WebAuthn) on all admin accounts.
- Rotate the admin username away from `admin` and use a long randomly-generated password stored in a password manager.
- Emit `Retry-After` and a generic `429` response after threshold; alert the site owner on repeated failures.

H1: Anonymous FTP service exposes files and enables unauthenticated data disclosure

Score	7.5 (High)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Target	• 51.161.131.195:21 (vsftpd 3.0.5) • media.thedownundernews.online
References	• https://cwe.mitre.org/data/definitions/284.html • https://cwe.mitre.org/data/definitions/200.html • https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-52r2.pdf

Overview

The media server exposes an FTP service on port 21 that permits anonymous login (username `anonymous`, any password). Any Internet user can list and download every file placed in the FTP root without any credentials, and the underlying protocol transmits everything in cleartext. Four files were already publicly enumerable at the time of assessment, including a small HTML file that carries an active JavaScript payload (`<script>alert(document.domain)</script>DUNHTML7731`), a 611 KB PDF, and two PNG screenshots (both created with `gnome-screenshot`, likely internal artefacts).

Details

Reproduction and evidence:

- `nmap -sV -p 21 51.161.131.195` identifies the service as **vsftpd 3.0.5**.
- Anonymous login succeeded (FTP 230 response) and the root directory contents were retrieved.
- Files present:
 - `37550846eae5457d93ddd8e1d2faeaca.html` (76 bytes) — contains `<script>alert(document.domain)</script>DUNHTML7731`.
 - `58e75939c3d24841806d3a069e919576.png` (231 KB) — `gnome-screenshot` artefact.
 - `66ea642847be4ef0a800fb8cb8432d79.png` (167 KB) — `gnome-screenshot` artefact.
 - `d2273a1a2576489fb419cc1049c4c62f.pdf` (611 KB) — a public academic paper; PDF metadata reveals producer "Adobe PDF Library 23.6.136".
- Directory permissions are read-only for anonymous, so uploads are not currently possible. If uploads become enabled in the future, the same anonymous access would allow attackers to plant arbitrary files.
- FTP itself has no encryption; any authenticated-user credentials or transferred files can be intercepted on the network path.
- Because these files appear to back the `media.thedownundernews.online` subdomain (which is currently returning HTTP 502 — upstream down), any of these files could later be served over the web, which would immediately expose the HTML file's active `<script>` payload to every visitor as a **Stored Cross-Site Scripting** condition.

Business impact:

- Any file placed on the media server is publicly downloadable by anyone in the world.
- Uploading confidential documents (drafts, contracts, subscriber data) to this server would immediately leak them.
- If the media subdomain is restored, the currently-stored malicious HTML file will execute JavaScript in every visitor's browser (Stored XSS).
- The cleartext protocol allows a network attacker to intercept files and any credentials.

Recommendation

- Disable anonymous FTP immediately (in `vsftpd.conf` set `anonymous_enable=NO`).
- Prefer SFTP (over SSH) or a modern object-storage upload service. If FTP must be used, require TLS (`ssl_enable=YES`, `force_local_data_ssl=YES`, `force_local_logins_ssl=YES`).
- Delete the four files currently exposed (in particular the `.html` file carrying the `alert()` payload) after archiving them.
- Review who uploaded each file and via what process; audit the workflow that put an `alert()`-carrying HTML page on the media host.
- Firewall port 21 from the public Internet if the service is only used internally.

H2: Public API leaks administrator identity, role, and account status

Score	7.5 (High)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Target	• https://www.thedownundernews.online/api/articles • https://www.thedownundernews.online/api/search • https://www.thedownundernews.online/api/categories
References	• https://cwe.mitre.org/data/definitions/200.html • https://owasp.org/API-Security/editions/2023/en/0xa3-broken-object-property-level-authorization/

Overview

Three unauthenticated JSON API endpoints return a nested `author` object containing the site administrator's real email address, username, internal user ID, role (`admin`), account-active status, and account-creation timestamp for every article. Attackers can harvest this information without any login and use it to seed targeted attacks (spear-phishing the admin, credential-stuffing the admin account, or building an org chart of site staff).

Details

Reproduction and evidence:

- GET `https://www.thedownundernews.online/api/articles` returns HTTP `200` with `Content-Type: application/json`. Each article object contains:

```
"author": {
  "created_at": "2026-09-13T13:16:02.003617+00:00",
  "email": "admin@thedownundernews.it.com",
  "first_name": "Site",
  "id": 1,
  "is_active": true,
  "last_name": "Administrator",
  "role": "admin",
  "username": "admin"
}
```

- The same disclosure repeats in every article returned by `/api/articles` and every search result at `/api/search?q=...`.
- `/api/categories` exposes category IDs, descriptions, display order, and article counts (less sensitive, but part of the same undocumented API surface).

- No authentication, API key, or CORS restriction to another origin is enforced (the endpoint sets Access-Control-Allow-Origin: `https://thedownundernews.online` which does not stop server-side attackers from harvesting the data).
- The admin email domain is `thedownundernews.it.com`, which the site owner confirmed is **not currently owned**. This is either an unregistered vanity domain (typo-squattable) or an artefact from an earlier planning phase and is itself a subsidiary data-hygiene concern.

Business impact:

- Attackers can identify the sole administrator, know that the account is still active, know the exact username used at `/admin/login`, and know a plausible contact email for phishing.
- Combined with the "no rate-limiting on `/admin/login`" finding, this enables a targeted credential-guessing attack because the attacker no longer needs to enumerate usernames.
- The `thedownundernews.it.com` email domain, if not registered by the owner, could be registered by an attacker to receive mail intended for the admin (including password-reset emails from any third-party services that email that address).

Recommendation

- Change the article serializer used by the API so that the `author` object only exposes public fields (for example `display_name`), never `email`, `id`, `role`, `is_active`, `username`, or `created_at`.
- Return the minimum data needed by the site UI. If the frontend does not need author identity at all, remove the field.
- Rotate the admin username to something not equal to `admin`, and enforce multi-factor authentication on the admin account (see the rate-limiting finding).
- Decide whether to register `thedownundernews.it.com` defensively, or remove all references to it from the platform (database seed data, configuration, footer links).

H3: Flask application directly exposed on port 5000, bypassing nginx

Score	7.3 (High)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L
Target	http://51.161.130.70:5000/
References	https://nvd.nist.gov/vuln/detail/CVE-2007-6750

Overview

The same Flask/Gunicorn application that is served through the hardened nginx reverse proxy on port 443 is also directly reachable on port 5000 without TLS and without any of nginx's protections. Any attacker on the Internet can bypass whatever rate limits, WAF rules, security headers, or TLS enforcement the nginx layer adds, simply by connecting to port 5000.

Details

Reproduction and evidence:

- `nmap -sV -p 5000 51.161.130.70` identifies the service as Gunicorn.
- Fetching `http://51.161.130.70:5000/` returns HTTP 200 with the title `The Down Under News - Australia's Independent Online Newspaper` — the exact same application content served on 443.
- The `Server` header on port 5000 is `gunicorn` (versus `nginx` on 443), confirming the response comes directly from the WSGI server.
- The nmap script `http-slowloris-check` flagged port 5000 as **likely vulnerable** to slow-HTTP resource exhaustion (CVE-2007-6750). Active DoS testing was not attempted, in accordance with the engagement rules of engagement.
- The **Werkzeug debug console was NOT exposed** (checked `/console` and `__debugger__` probes — all denied). This is the good news: the immediate remote code-execution risk is not present.

Business impact:

- Any request-based rate limiting, IP blocking, or WAF rule added at the nginx layer is trivially bypassed by moving to port 5000.
- Cleartext HTTP on 5000 leaks user session cookies to any network observer between the visitor and the VPS.
- Slowloris-style resource exhaustion (unverified but plausible for a bare Gunicorn on the Internet) can DoS the backend.

Recommendation

- Bind Gunicorn to `127.0.0.1:5000` (or a UNIX socket) and only allow nginx to speak to it locally.
- If Gunicorn must listen on the public IP for a reason, firewall port 5000 with `iptables` / `nftables` / `UFW` or the OVH network firewall.
- Configure Gunicorn timeouts (`--timeout`, `--graceful-timeout`) and worker limits to blunt slow-request attacks even after the port is closed to the Internet.

H4: Missing anti-CSRF protection on state-changing forms (admin login and comment submission)

Score	7.1 (High)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:H/A:N
Target	• https://www.thedownundernews.online/admin/login (POST) • https://www.thedownundernews.online/article/{slug}/comment (POST)
References	• https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html • https://cwe.mitre.org/data/definitions/352.html

Overview

Both the administrator login form and the comment-submission form accept POST requests without validating any anti-cross-site-request-forgery (CSRF) token. A hidden token or SameSite cookie policy that would tie the request to the user's session was not present. This allows an attacker-controlled page to trigger state-changing actions when a logged-in admin (or any site visitor) visits the attacker's page.

Details

Reproduction and evidence:

- Reviewing the HTML of `/admin` (evidence file `page-admin.html`) and the comment form on any article page shows no hidden input carrying a CSRF token (no `csrf_token`, `_token`, `authenticity_token` or similar). No custom header (e.g. `X-CSRF-Token`) is required by the endpoints.
- Session cookies were captured on the comment endpoint; the cookie has `HttpOnly=true` but `Secure=false` and `SameSite` is not set (see also the session-cookie-flags finding).
- Comment submissions work purely on cookie-based session identity; a malicious external page can auto-post to `/article/{slug}/comment` on behalf of any visitor.

Business impact:

- **Comment CSRF:** attackers can force any site visitor to unwittingly post comments in their name (spam, defamation, illegal content, discovery of visitor identity by seeing the comment appear).
- **Admin login CSRF:** less directly damaging (an attacker forcing a login attempt still needs credentials), but paired with any admin-only state-changing endpoint the same class of vulnerability likely exists (e.g. POST endpoints under `/admin/...` which redirect when unauthenticated) — those should be verified when authenticated.

Recommendation

- Adopt `Flask-WTF` or an equivalent CSRF middleware and require a token on every POST that changes server state.
- Set session cookies with `Secure=true`, `SameSite=Lax` (or `Strict`) and `HttpOnly=true`.
- Enforce origin / referer checks on privileged POSTs as a defence-in-depth layer.

M1: No CAA record - any Certificate Authority in the world can issue a certificate for the domain

Score	6.8 (Medium)
Vector string	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:N/A:N
Target	thedownundernews.online (DNS)
References	https://datatracker.ietf.org/doc/html/rfc8659

Overview

The DNS zone has no CAA (Certification Authority Authorization) record. This means every publicly-trusted CA on the CA/B Forum root list is allowed to issue TLS certificates for the domain and its subdomains. A single compromised or misbehaving CA (or a CA tricked by a domain-hijack, BGP-hijack, or DNS cache poisoning) would be able to issue a valid mis-issued certificate.

Details

Reproduction and evidence:

- `dig +short CAA thedownundernews.online @1.1.1.1` returned no records.
- The site uses Let's Encrypt today.

Recommendation

- Add a CAA record restricting issuance to the intended CA(s), for example:

```
thedownundernews.online. IN CAA 0 issue "letsencrypt.org"  
thedownundernews.online. IN CAA 0 iodef "mailto:security@thedownundernews.online"
```

- Add `issuewild` if wildcard certs are used.
- Ensure the `iodef` mailbox is real and monitored.

M2: Server error (HTTP 500) triggered by posting a comment to a non-existent article

Score	6.5 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:L
Target	https://www.thedownundernews.online/article/<any-invalid-slug>/comment (POST)
References	https://cwe.mitre.org/data/definitions/755.html

Overview

Submitting a comment `POST` to any URL that follows the pattern `/article/{slug}/comment` where `{slug}` does not correspond to a real article causes the server to return `HTTP 500 Internal Server Error` instead of a validated `404`. This indicates an unhandled exception in the comment handler and can be triggered repeatedly by any unauthenticated user.

Details

Reproduction and evidence:

- `POST https://www.thedownundernews.online/article/nonexistent-clawsec-slug-<timestamp>/comment` returned `HTTP 500` with body `<h1><p>Internal Server Error</p></h1>`.
- The error is generic (no stack trace leaked — which is good), but the fact that a routine "wrong URL" triggers a `500` shows the comment endpoint does not validate the article slug before attempting whatever database operation follows.
- Any unauthenticated user can send arbitrary POSTs at rate and force the app to raise exceptions on every request.

Business impact:

- **Log noise / alert fatigue:** production error monitoring will be flooded with false-positive `500`s and real errors will be lost in the noise.
- **Potential resource exhaustion:** if the exception is expensive (open DB connections, long stack unwind, sentry capture, etc.) an attacker can generate load with minimal effort.
- **Latent risk:** an unhandled exception path in the comment handler suggests other input-validation gaps in the same code path that might be more directly exploitable.

Recommendation

- In the comment view, look up the article by slug first and return `404` explicitly if not found, before any DB write.
- Wrap the whole handler in appropriate exception handling and return the proper error code.

- Add unit / integration tests that POST comments to non-existent slugs and expect a validated 404.

M3: Website is missing baseline HTTP security headers	
Score	5.4 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N
Target	• https://www.thedownundernews.online/ • https://thedownundernews.online/ • https://media.thedownundernews.online/ • http://51.161.130.70:5000/
References	• https://cheatsheetseries.owasp.org/cheatsheets/HTTP-Headers-Cheat-Sheet.html • https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security

Overview

None of the site's HTTP responses carry the baseline security headers that modern browsers use to defend against common web attacks. The following are all missing across every tested endpoint: Strict-Transport-Security, Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy, and the Cross-Origin-* family.

Details

Observed headers on GET https://www.thedownundernews.online/ (via curl -I):

```
Server: nginx
Date: ...
Content-Type: text/html; charset=utf-8
Content-Length: ...
Connection: keep-alive
```

No security-relevant headers are present. Nikto independently reports the same.

Consequences:

- **No HSTS:** browsers can be downgraded to plain HTTP by a network attacker on the first visit (SSL-strip). This directly weakens the "session cookie without Secure" finding.
- **No CSP:** a single script-injection anywhere (an XSS in some future feature) has no browser-side mitigation.
- **No X-Frame-Options / frame-ancestors:** the site can be embedded in iframes for clickjacking (of the admin panel in particular).
- **No X-Content-Type-Options:** MIME-sniffing can turn a benign upload into an active script.
- **No Referrer-Policy:** full referrers (with query strings) are sent to all off-site clicks (analytics, ads).

- **No Permissions-Policy:** browsers grant unrestricted feature access (camera, mic, geolocation, etc.) if any code requests it.

Recommendation

Add the following headers at the nginx layer (or via Flask middleware) — as a safe starting configuration:

```
add_header Strict-Transport-Security "max-age=63072000; includeSubDomains; preload"
always;
add_header Content-Security-Policy "default-src 'self'; script-src 'self' https://
cdn.jsdelivr.net; style-src 'self' https://fonts.googleapis.com https://cdn.jsdelivr.net
'unsafe-inline'; font-src 'self' https://fonts.gstatic.com; img-src 'self' data;; base-uri
'self'; form-action 'self'; frame-ancestors 'self'; upgrade-insecure-requests" always;
add_header X-Frame-Options SAMEORIGIN always;
add_header X-Content-Type-Options nosniff always;
add_header Referrer-Policy strict-origin-when-cross-origin always;
add_header Permissions-Policy "camera=(), microphone=(), geolocation=(), interest-
cohort=()" always;
```

Consider submitting the domain to the HSTS preload list once HSTS is deployed and validated in production.

M4: Session cookie is not marked Secure and SameSite is not set

Score	5.3 (Medium)
Vector string	CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:N/A:N
Target	session cookie set on https://www.thedownundernews.online/
References	• https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html • https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Set-Cookie

Overview

The application's session cookie is `HttpOnly` (good) but does not have the `Secure` flag and does not specify `SameSite`. Without `Secure`, a browser will send the cookie over plain HTTP if it can be induced to make a plain-HTTP request to the domain (which is easy because HSTS is missing). Without `SameSite`, the cookie is included in cross-site requests, enabling CSRF (see the CSRF finding).

Details

Reproduction and evidence:

- After POST to `/article/{slug}/comment`, the response `Set-Cookie` was: `session=<value>; Path=/; HttpOnly`.
- No `Secure` attribute.
- No `SameSite` attribute.
- The site does not send HSTS, so a first-time visitor typing `thedownundernews.online` in the address bar will make a plain-HTTP request that the site does redirect to HTTPS — but a network attacker in between can strip that redirect and observe (and later steal) the session cookie.

Business impact:

- Session hijack on hostile networks (public Wi-Fi, malicious ISP, compromised router).
- CSRF against comment posting and any other cookie-authenticated endpoint.

Recommendation

- In Flask: set `app.config['SESSION_COOKIE_SECURE'] = True`, `SESSION_COOKIE_SAMESITE = 'Lax'` (or `'Strict'` for admin routes), keep `HttpOnly = True`.
- Add HSTS (see the security-headers finding) so that first-visit HTTP is impossible in modern browsers after the first successful HTTPS load.

M5: SSH server offers legacy HMAC-SHA1 message authentication codes

Score	4.8 (Medium)
Vector string	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N
Target	• 51.161.130.70:22 (OpenSSH 10.0p2 Debian 7+deb13u4) • 51.161.131.195:22 (OpenSSH 10.0p2 Debian 7+deb13u4)
References	https://datatracker.ietf.org/doc/html/rfc6194

Overview

Both SSH servers advertise `hmac-sha1` and `hmac-sha1-etm@openssh.com` among the MAC algorithms they support. These SHA-1-based MACs are cryptographically deprecated and should not be offered on Internet-facing SSH.

Details

Reproduction and evidence:

- nmap NSE `ssh2-enum-algos` output (evidence `nmap-ssh-audit.txt`) lists MAC algorithms including:

```
umac-64-etm, umac-128-etm, hmac-sha2-256-etm, hmac-sha2-512-etm,  
hmac-sha1-etm@openssh.com, umac-64, umac-128,  
hmac-sha2-256, hmac-sha2-512, hmac-sha1
```

- Modern SHA-2 based MACs are preferred by clients, so this is unlikely to be actively negotiated in most sessions, but availability alone is a Low-severity finding.
- Key exchange, host keys, and ciphers are all modern (`mlkem768x25519-sha256`, `curve25519-sha256`, `ecdsa-sha2-nistp256`, `ssh-ed25519`, `chacha20-poly1305`, `aes*-gcm`, `aes*-ctr`). No SSHv1. No `ssh-rsa` (SHA-1). No `3des-cbc` / `arcfour` / `blowfish-cbc`.

Note on OpenSSH vulnerabilities: the nmap `vulners` script mapped a long list of 2026-vintage CVE identifiers against the observed OpenSSH banner. `vulners` often reports version-string matches that do not reflect the Debian-patched build; each of those CVEs would need to be verified against the Debian security tracker. They are therefore treated as candidates for a follow-up review rather than confirmed findings in this report.

Recommendation

- Edit `/etc/ssh/sshd_config` on both VPS and restrict MACs to strong SHA-2 variants:

```
MACs hmac-sha2-512-etm@openssh.com,hmac-sha2-256-etm@openssh.com,umac-128-  
etm@openssh.com
```

- `systemctl reload ssh.`
- Verify with `ssh -Q mac` and re-run `nmap -p 22 --script ssh2-enum-algos.`

M6: TLS certificate does not cover the "www" hostname (browser warning)

Score	4.7 (Medium)
Vector string	CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:C/C:L/I:L/A:N
Target	https://www.thedownundernews.online/
References	https://cwe.mitre.org/data/definitions/297.html

Overview

When a visitor loads `https://www.thedownundernews.online/`, the TLS certificate presented has Common Name `thedownundernews.online` and Subject Alternative Name `[thedownundernews.online]` only. It does not include the `www` hostname. Modern browsers therefore display a full-page security warning ("Your connection is not private" / `NET::ERR_CERT_COMMON_NAME_INVALID`) and force the visitor to bypass a scary security screen before reaching the site.

Details

Reproduction and evidence:

- `openssl s_client -connect www.thedownundernews.online:443` confirms the presented certificate covers only the apex domain.
- `ssllscan` (evidence `ssllscan.txt`) shows the same: `SAN = DNS:thedownundernews.online`.
- Nikto flags the mismatch as CWE-297.
- Certificate issuer is Let's Encrypt (short-lived; renewal every 90 days), so this is a Certbot / DNS configuration oversight, not a fundamental PKI limitation.

Business impact:

- Every visitor that types `www.thedownundernews.online` (a very common habit) sees a full-screen browser warning suggesting the site may be a phishing site.
- Trust in the brand is damaged; conversion, engagement, and ad revenue all suffer.
- Users trained to click through the warning become desensitised, undermining certificate warnings site-wide.

Recommendation

- Reissue the certificate to include both `thedownundernews.online` and `www.thedownundernews.online` in the SAN list. With certbot: `certbot --nginx -d thedownundernews.online -d www.thedownundernews.online`.

- Alternatively, HTTP-redirect `www` to the apex before TLS negotiation (not usually possible with modern browsers) — the correct fix is to add the SAN and let the redirect happen after TLS.
- Add both hostnames to the automatic renewal configuration.

I1: /admin/login accepts JSON content-type for a form endpoint

Score	0.0 (Info)
Vector string	N/A
Target	https://www.thedownundernews.online/admin/login
References	-

Overview

The login endpoint accepts POSTs with `Content-Type: application/json` in addition to the expected `application/x-www-form-urlencoded` and returns a JSON-formatted 401 in that case. This loose content-type handling widens the CSRF attack surface (JSON POSTs are traditionally not considered "simple" CORS requests, so some CSRF defences that rely on that assumption may be bypassed) and increases the risk of parser confusion.

Details

Reproduction and evidence:

- `curl -X POST -H "Content-Type: application/json" -d '{"username":"x","password":"y"}'` `https://www.thedownundernews.online/admin/login` returned HTTP 401 with body `{"error":"Invalid credentials"}`.
- The same POST with form encoding returns an HTML 401 error page.

Recommendation

- Explicitly require `Content-Type: application/x-www-form-urlencoded` on `/admin/login` and reject other content types with 415 Unsupported Media Type.
- Combined with the CSRF-token finding, this closes both traditional and JSON-CSRF vectors.

I2: Contact form silently discards all messages (deceptive UI, business data loss)

Score	0.0 (Info)
Vector string	N/A
Target	https://www.thedownundernews.online/contact
References	-

Overview

The public contact form on the website does not send messages anywhere. The page shows a "Your message has been sent successfully" confirmation after submit, but the submission is handled entirely in the browser by JavaScript that calls `preventDefault()` and never actually transmits data to the server. Every message a reader tries to send is silently thrown away while the reader is told the message was delivered.

Details

Reproduction and evidence:

- Reviewing the HTML at `/contact` (evidence file `page-contact.html`), the form has `id="contactForm"` but no server-side `action` attribute wired for submission.
- The inline JavaScript block is:

```
document.getElementById('contactForm').addEventListener('submit', function(e){
  e.preventDefault();
  document.getElementById('contactSuccess').style.display='flex';
  this.reset();
});
```

This intercepts the submit event, cancels the browser submit, then displays a static "success" panel and resets the form.

- POSTing directly to `/contact` returns HTTP 405 Method Not Allowed, which confirms no server endpoint is bound.
- There is no `fetch()`, `XMLHttpRequest`, or `WebSocket` call in `main.js` or in the inline scripts that would forward the message anywhere.

Business impact:

- Every contact request from readers, journalists, advertisers, tip-line submitters, complaints, right-of-reply, or take-down demands is silently lost.

- Users are deceived into believing the message reached DownUnderNewsz; they will not resend or follow up by other channels.
- Legal / regulatory obligations (for example newsroom right-of-reply requests, defamation notices, or GDPR-style data-subject requests) can be missed with no audit trail.

Recommendation

- Implement a server endpoint (for example `POST /contact`) that stores messages in the database, forwards to an admin email, or files them into a ticketing system.
- Add server-side validation, rate limiting, and CSRF protection to that endpoint.
- Until fixed, either take the contact page down or replace the fake success message with a direct email address (`info@...` or `editor@...`).
- Add a CAPTCHA and an anti-abuse rate limit before going live.

I3: Email domain is not protected against spoofing (DMARC missing, DKIM missing, SPF is soft-fail)	
Score	0.0 (Info)
Vector string	N/A
Target	thedownundernews.online (mail domain)
References	• https://datatracker.ietf.org/doc/html/rfc7489 • https://datatracker.ietf.org/doc/html/rfc6376

Overview

The DNS zone for `thedownundernews.online` has weak email-authentication configuration. There is no DMARC policy, no DKIM selector could be enumerated for the domain, and SPF ends with `~all` (soft fail). This makes it trivially easy for an attacker to send email that appears to come from any `@thedownundernews.online` address without being blocked by receiving mail servers.

Details

Records observed (dig +short against 1.1.1.1):

- **SPF** (TXT `thedownundernews.online`): `"v=spf1 include:spf.efwd.spaceship.net ~all"`
 - Uses `~all` (soft fail); receivers should mark as "may be spam" rather than reject.
- **DMARC** (TXT `_dmarc.thedownundernews.online`): empty (no record).
 - Without DMARC, receivers cannot enforce SPF or DKIM alignment.
- **DKIM**
(TXT `default._domainkey / google._domainkey / selector1._domainkey / mail._domainkey / spaceship._domainkey ...`): all empty.
 - No DKIM signing appears to be configured.
- **MX**: `mx1.efwd.spaceship.net`, `mx2.efwd.spaceship.net` (Spaceship email forwarding).
- **CAA**: empty (see separate finding).
- **DNSSEC**: `signedDelegation` (this is good; retain).

Business impact:

- Attackers can spoof `@thedownundernews.online` sender addresses in phishing campaigns targeting readers, staff, advertisers, or newsroom contacts. Recipients will see legitimate-looking sender addresses.
- Because DMARC is missing, the domain gets no visibility (no aggregate DMARC reports) into ongoing spoofing attempts.
- Reputational and legal exposure if a fraudster impersonates an editor or the newsroom.

Recommendation

- Publish DMARC as TXT `_dmarc.thedownundernews.online`:

```
v=DMARC1; p=none; rua=mailto:dmarc-reports@thedownundernews.online; ruf=mailto:dmarc-reports@thedownundernews.online; fo=1; adkim=s; aspf=s
```

Start with `p=none` for 2–4 weeks to collect aggregate reports; then escalate to `p=quarantine`, then `p=reject`.

- Enable DKIM signing at the mail provider (Spaceship `efwd`). Publish the corresponding `_domainkey` TXT record.
- Tighten SPF from `~all` to `-all` (hard fail) once DKIM+DMARC visibility confirms all legitimate senders are covered.
- Register the `thedownundernews.it.com` domain defensively (see the API disclosure finding) so it cannot be used to spoof mails from the admin.

I4: Website exposes minor information-disclosure and hygiene artefacts

Score	0.0 (Info)
Vector string	N/A
Target	• https://www.thedownundernews.online/ • 51.161.131.195 (FTP)
References	https://datatracker.ietf.org/doc/html/rfc9116

Overview

Several small hardening items are worth mentioning together. None are individually severe, but together they slightly lower the site's overall security posture.

Details

1. **Server header discloses nginx** (version is hidden — good). Consider suppressing the server token entirely via `server_tokens off` and, if desired, `add_header Server ""` always.
2. **/robots.txt returns 404**. A minimal `/robots.txt` makes crawler policy explicit and enables an easy path to future `/sitemap.xml`.
3. **/sitemap.xml returns 404**. Publishing one improves SEO (relevant for a news site) and also makes indexing more predictable.
4. **/.well-known/security.txt returns 404**. Consider publishing a `security.txt` (RFC 9116) so researchers can privately report issues; this is common for media companies.
5. **Leftover XSS-marker HTML file on anonymous FTP**. The file `<hash>.html` on anonymous FTP contains a JavaScript `alert()` payload and a marker `DUNHTML7731`. It looks like a leftover from an earlier security test or from a file-upload probe that was never cleaned up. Delete it (see the FTP finding).
6. **Admin email references an unregistered domain**. The API leaks an admin email at `admin@thedownundernews.it.com`. The owner has stated that `thedownundernews.it.com` is not currently owned by the business. Either register the domain defensively or remove all references to it from configuration and seed data.
7. **Very recent domain registration**. `thedownundernews.online` was registered 2026-08-04 via Spaceship (very recent), which is fine but means the attack surface visible in certificate-transparency logs will grow over the next 90 days as new sub-certs are minted.

Recommendation

- Publish `/robots.txt`, `/sitemap.xml`, and `/.well-known/security.txt`.
- Suppress the `Server` header token.
- Register the `.it.com` domain defensively **or** purge it from application data.

- Delete the FTP files (see the FTP finding).
- Re-run passive OSINT and CT-log enumeration in 30–90 days.

I5: media.thedownundernews.online is broken (HTTP 502 Bad Gateway)

Score	0.0 (Info)
Vector string	N/A
Target	https://media.thedownundernews.online/
References	-

Overview

The media subdomain is configured in DNS and served by nginx on 51.161.131.195, but nginx cannot reach its upstream and returns HTTP 502 for every request. Media files (article images, downloads) are therefore not being delivered to readers.

Details

Reproduction and evidence:

- Every GET to https://media.thedownundernews.online/ returns HTTP 502 Bad Gateway (Server: nginx).
- The TLS certificate for this hostname is valid and correctly configured (CN=media.thedownundernews.online).
- The backend responsible for serving these files (probably a small Flask app or a direct static file server) is not running or not listening on the port nginx is proxying to.

Business impact:

- Articles that reference images or other media hosted on this subdomain will display broken content.
- If the site owner uploads new media, readers will not see it.

Recommendation

- Check the systemd service for the media backend on 51.161.131.195: `systemctl status <media-service>; journalctl -u <media-service>` to see why it is down.
- Once the media backend is restored, **do not** expose the FTP-hosted files until they have been vetted (specifically, delete the .html file carrying the alert() payload first — see the FTP finding). Serving that file over HTTP would create a Stored XSS.

5 Disclaimer

The purpose of this research project is to help evaluating the seamlessness, effectiveness and cost-benefit ratio of autonomously performing vulnerability assessment using agentic AI. I do not take any responsibility upon any misuse or abuse of such tool where it can face significant legal actions.

A Appendix

A.1 Static Appendix Section

A.2 Tools used during the assessment

The following tools were used during the engagement. All were run from a Kali Linux workstation against the authorised in-scope assets only, in a non-destructive configuration.

- **nmap** — TCP port sweeps, service/version detection, and safe NSE scripts (including `ssh2-enum-algos`, `http-slowloris-check`, `vulners`).
- **ffuf** — HTTP endpoint enumeration against the web application using a common wordlist.
- **nuclei** — Template-based vulnerability scanning (~10 000 templates) against the public web endpoints.
- **nikto** — Web-server misconfiguration and header hygiene scan.
- **whatweb** — Web technology fingerprinting.
- **ssllscan** — TLS configuration and cipher-suite review on the three HTTPS endpoints.
- **dig** — DNS record enumeration (A, AAAA, MX, TXT/SPF, TXT/DMARC, TXT/DKIM selectors, CAA, DNSKEY).
- **openssl s_client** — Manual TLS certificate inspection (issuer, SANs, validity, chain).
- **curl** — Manual HTTP request crafting, header inspection, verb-tampering and content-type probing.
- **exiftool** — Metadata extraction from files retrieved from the anonymous FTP service.
- **pdftinfo / pdftotext** — Metadata and text extraction from the PDF file retrieved from the anonymous FTP service.

A.3 Prerequisites and testing limitations

- Testing was time-boxed to a single day. Areas noted as unverified (in particular Stored XSS on the article comment field) should be revisited during the remediation phase.
- No credentials were provided; the assessment covered only the unauthenticated attack surface. An authenticated review of the `/admin` panel is recommended once rate-limiting and MFA are in place.
- Denial-of-service, brute-force, social-engineering, and destructive techniques were explicitly excluded by the rules of engagement. The `http-slowloris-check` NSE result for port 5000 is a *candidate* only — it was not actively confirmed.
- OpenSSH CVE matches reported by `nmap vulners` are version-string matches and do not reflect the Debian-patched build; they are called out as candidates for follow-up review against the Debian security tracker, not as confirmed findings.
- Out-of-scope assets (Spaceship, other OVH infrastructure, Cloudflare, jsDelivr, Google Fonts, Let's Encrypt, Flinders University, `thedownundernews.it.com`) were not tested.